Website Vulnerability Scanner Report

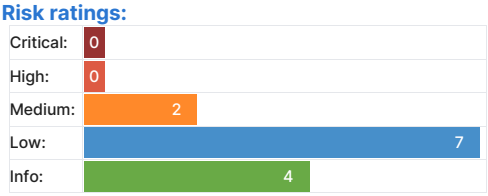
✔ https://google-gruyere.appspot.com/6089779068945906258916178499883858380 39/

The Light Website Scanner didn't check for critical issues like SQLi, XSS, Command Injection, XXE, etc.
Upgrade to run Deep scans with 40+ tests and detect more vulnerabilities.

Summary

Overall risk level:
Medium

Risk ratings:



Scan information:

Start time:	Oct 10, 2026 / 22:19:48 UTC+0530
Finish time:	Oct 10, 2026 / 22:20:05 UTC+0530
Scan duration:	17 sec
Tests performed:	40
Scan status:	Finished

Findings

Insecure cookie setting: missing Secure flag

port 443/tcp

CONFIRMED

URL	Cookie Name	Evidence
https://google-gruyere.appspot.com/6089779068945906258916178499883858380 39/saveprofile	GRUYERE	Set-Cookie: GRUYERE=31391908|1d3d2d231d2dd4||author Request / Response

Details

Risk description:
The risk exists that an attacker will intercept the clear-text communication between the browser and the server and he will steal the cookie of the user. If this is a session cookie, the attacker could gain unauthorized access to the victim's web session.

Recommendation:
Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.

References:
https://wstg.owasp.org/v4.2/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes/

Classification:
CWE : CWE-614
OWASP Top 10 - 2017 : A6 - Security Misconfiguration
OWASP Top 10 - 2021 : A5 - Security Misconfiguration
OWASP Top 10 - 2025 : A02 - Security Misconfiguration
SOC 2 : CC6.1 - Logical access and session security
ISO 27001 : A.5.15 - Access control

Insecure cookie setting: missing HttpOnly flag

port 443/tcp

CONFIRMED

URL	Cookie Name	Evidence
https://google-gruyere.appspot.com/6089779068945906258916178499883858380 39/saveprofile	GRUYERE	The server responded with Set-Cookie header(s) that does not specify the HttpOnly flag: Set-Cookie: GRUYERE=31391908|1d3d2d231d2dd4||author Request / Response

Details

Risk description:
The risk is that an attacker who injects malicious JavaScript code on the page (e.g. by using an XSS attack) can access the cookie and can send it to another site. In case of a session cookie, this could lead to session hijacking.

Recommendation:
Ensure that the HttpOnly flag is set for all cookies.

References:
https://owasp.org/www-community/HttpOnly

Classification:
CWE : CWE-1004
OWASP Top 10 - 2017 : A6 - Security Misconfiguration
OWASP Top 10 - 2021 : A5 - Security Misconfiguration
OWASP Top 10 - 2025 : A02 - Security Misconfiguration
SOC 2 : CC6.1 - Logical access and session security
ISO 27001 : A.5.15 - Access control

Missing security header: X-Content-Type-Options

CONFIRMED

port 443/tcp

URL	Evidence
https://google-gruyere.appspot.com/6089779068945906258916178499883858380 39/	Response headers do not include the X-Content-Type-Options HTTP security header Request / Response

Details

Risk description:
The risk is that lack of this header could make possible attacks such as Cross-Site Scripting or phishing in Internet Explorer browsers.

Recommendation:
We recommend setting the X-Content-Type-Options header such as `X-Content-Type-Options: nosniff` .

References:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options

Classification:
CWE : CWE-693
OWASP Top 10 - 2017 : A6 - Security Misconfiguration
OWASP Top 10 - 2021 : A5 - Security Misconfiguration
OWASP Top 10 - 2025 : A02 - Security Misconfiguration
SOC 2 : CC6.6 - Security configuration, boundary protection, and exposure hardening
ISO 27001 : A.8.9 - Configuration management

Missing security header: Content-Security-Policy

CONFIRMED

port 443/tcp

URL	Evidence
https://google-gruyere.appspot.com/6089779068945906258916178499883858380 39/	Response does not include the HTTP Content-Security-Policy security header or meta tag Request / Response

Details

Risk description:
The risk is that if the target application is vulnerable to XSS, lack of this header makes it easily exploitable by attackers.

Recommendation:
Configure the Content-Security-Header to be sent with each HTTP response in order to apply the specific policies needed by the application.

References:
https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy

Classification:
CWE : CWE-1021
OWASP Top 10 - 2017 : A6 - Security Misconfiguration
OWASP Top 10 - 2021 : A5 - Security Misconfiguration
OWASP Top 10 - 2025 : A02 - Security Misconfiguration
SOC 2 : CC6.6 - Security configuration, boundary protection, and exposure hardening
ISO 27001 : A.8.9 - Configuration management

Missing security header: Referrer-Policy

CONFIRMED

port 443/tcp

URL	Evidence
https://google-gruyere.appspot.com/6089779068945906258916178499883858380 39/	Response headers do not include the Referrer-Policy HTTP security header as well as the <meta> tag with name 'referrer' is not present in the response. Request / Response

Details

Risk description:
The risk is that if a user visits a web page (e.g. "http://example.com/pricing/") and clicks on a link from that page going to e.g. "https://www.google.com", the browser will send to Google the full originating URL in the `Referer` header, assuming the Referrer-Policy header is not set. The originating URL could be considered sensitive information and it could be used for user tracking.

Recommendation:
The Referrer-Policy header should be configured on the server side to avoid user tracking and inadvertent information leakage. The value `no-referrer` of this header instructs the browser to omit the Referer header entirely.

References:
https://developer.mozilla.org/en-US/docs/Web/Security/Referer_header:_privacy_and_security_concerns

Classification:
CWE : CWE-693
OWASP Top 10 - 2017 : A6 - Security Misconfiguration
OWASP Top 10 - 2021 : A5 - Security Misconfiguration
OWASP Top 10 - 2025 : A02 - Security Misconfiguration
SOC 2 : CC6.6 - Security configuration, boundary protection, and exposure hardening
ISO 27001 : A.8.9 - Configuration management

Missing security header: Strict-Transport-Security

CONFIRMED

port 443/tcp

URL	Evidence
https://google-gruyere.appspot.com/6089779068945906258916178499883858380 39/	Response headers do not include the HTTP Strict-Transport-Security header Request / Response

Details

Risk description:
The risk is that lack of this header permits an attacker to force a victim user to initiate a clear-text HTTP connection to the server, thus opening the possibility to eavesdrop on the network traffic and extract sensitive information (e.g. session cookies).

Recommendation:
The Strict-Transport-Security HTTP header should be sent with each HTTPS response. The syntax is as follows:

```
Strict-Transport-Security: max-age=<seconds>[; includeSubDomains]
```

The parameter `max-age` gives the time frame for requirement of HTTPS in seconds and should be chosen quite high, e.g. several months. A value below 7776000 is considered as too low by this scanner check.
The flag `includeSubDomains` defines that the policy applies also for sub domains of the sender of the response.

Classification:

CWE : CWE-693
OWASP Top 10 - 2017 : A6 - Security Misconfiguration
OWASP Top 10 - 2021 : A5 - Security Misconfiguration
OWASP Top 10 - 2025 : A02 - Security Misconfiguration
SOC 2 : CC6.6 - Security configuration, boundary protection, and exposure hardening
ISO 27001 : A.8.9 - Configuration management

Robots.txt file found

port 443/tcp

CONFIRMED

URL
https://google-gruyere.appspot.com/robots.txt

Details

Risk description:

There is no particular security risk in having a robots.txt file. However, it's important to note that adding endpoints in it should not be considered a security measure, as this file can be directly accessed and read by anyone.

Recommendation:

We recommend you to manually review the entries from robots.txt and remove the ones which lead to sensitive locations in the website (ex. administration panels, configuration files, etc).

References:

https://www.theregister.co.uk/2015/05/19/robotstxt/

Classification:

OWASP Top 10 - 2017 : A6 - Security Misconfiguration
OWASP Top 10 - 2021 : A5 - Security Misconfiguration
OWASP Top 10 - 2025 : A06 - Insecure Design
SOC 2 : CC6.6 - Security configuration, boundary protection, and exposure hardening
ISO 27001 : A.8.9 - Configuration management

Password Submitted in URL

port 443/tcp

UNCONFIRMED

URL	Method	Parameters	Evidence
			The following form sends inputs of type password plainly in the URL:

https://google-gruyere.appspot.com/6089779068945906258916178499838583 8039/editprofile.gtl	GET	**Headers:** User-Agent=Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/153.0.0.0 Safari/537.36 **Cookies:** GRUYERE=31391908|1d3d2d231d2dd4||author	<form method="get" action="/6089779068945906258916178499838583 8039/saveprofile"> <input type="hidden" name="action" value="update"> <table> <tbody><tr><td> User id: </td><td> 1d3d2d231d2dd4 </td></tr> <tr><td> User name: </td><td> <input type="text" value="1d3d2d231d2dd4" name="name" maxlength="16"> </td></tr> <tr><td> OLD Password: </td><td> <input type="password" name="oldpw"> </td><td> </td></tr> <tr><td> NEW Password: </td><td> <input type="password" name="pw"> WARNING: Gruyere is not secure. Do not use a password that you use for any real service. </td></tr> <tr><td> Icon: </td><td> <input type="text" value="" name="icon"> (32x32 image, URL to image location) </td></tr> <tr><td> Homepage: </td><td> <input type="text" size="50" value="" name="web_site"> </td></tr> <tr><td> Profile Color: </td><td> <input type="text" value="" name="color"> </td></tr> <tr><td> Private Snippet: </td><td> <textarea name="private_snippet" rows="... (truncated) Request / Response

https://google-gruyere.appspot.com/6089779068945906258916178499838583839/login	GET	**Headers:** User-Agent=Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/153.0.0.0 Safari/537.36	The following form sends inputs of type password plainly in the URL: `<form method="get" action="/6089779068945906258916178499883858380 39/login"> <table><tbody><tr><td> User name: </td><td> <input type="text" name="uid"> </td></tr><tr><td> Password: </td><td> <input type="password" name="pw"> </td></tr><tr><td></td><td align="right"> <input type="submit" value="Login"> </td></tr></tbody></table> </form>` Request / Response

https://google-gruyere.appspot.com/6089779068945906258916178499883858380 39/newaccount.gtl	GET	**Headers:** User-Agent=Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/153.0.0.0 Safari/537.36	The following form sends inputs of type password plainly in the URL: `<form method="get" action="/6089779068945906258916178499883858380 39/saveprofile"> <input type="hidden" name="action" value="new"> <table><tbody><tr> <td> User name: </td><td> <input type="text" name="uid" value="" maxlength="16"> </td></tr> <tr><td> Password: </td><td> <input type="password" name="pw"> WARNING: Gruyere is not secure. Do not use a password that you use for any real service. Do not upload any personal or private data. </td></tr> <input type="hidden" name="is_author" value="True"> <tr><td></td><td align="right"> <input type="submit" value="Create account"> </td></tr> </tbody></table> </form>` Request / Response

Details

Risk description:
Passwords submitted in URLs have a higher chance of being leaked. The main reason is that URLs can be leaked in browser cross-site requests via the Referer header. Additionally, URLs are usually stored in all kinds of logs. If any access or error logs of the server were publicly accessible, an attacker could also harvest password from it.

Recommendation:
You should submit passwords using POST rather than GET. This way sensitive data won't be shared to other locations via URLs.

References:
https://developer.mozilla.org/en-US/docs/Web/Security/Referer_header:_privacy_and_security_concerns

Classification:
CWE : CWE-598
OWASP Top 10 - 2021 : A4 - Insecure Design
OWASP Top 10 - 2025 : A06 - Insecure Design
SOC 2 : CC6.7 - Secure transmission / encryption in transit
ISO 27001 : A.5.17 - Authentication information

Server software and technology found

port 443/tcp

UNCONFIRMED

Software / Version	Category

Google Cloud	IaaS
Google Cloud Load Balancing	Load balancers
Google Cloud Trace	Performance
HTTP/3	Miscellaneous

Details

Risk description:
The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:
We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

References:
https://wstg.owasp.org/v4.2/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server/

Classification:
CWE : CWE-200
OWASP Top 10 - 2017 : A6 - Security Misconfiguration
OWASP Top 10 - 2021 : A5 - Security Misconfiguration
OWASP Top 10 - 2025 : A02 - Security Misconfiguration
SOC 2 : CC7.1 - Vulnerability identification and analysis
ISO 27001 : A.8.8 - Management of technical vulnerabilities

Login Interface Found

port 443/tcp

CONFIRMED

URL	Evidence

https://google-gruyere.appspot.com/6089779068945906258916178499883858380 39/newaccount.gtl	`<input type="text" name="uid" value="" maxlength="16">`
	`<input type="password" name="pw">`
	`<input type="submit" value="Create account">`
	
	Request / Response

Details

Risk description:
The risk is that an attacker could use this interface to mount brute force attacks against known passwords and usernames combinations leaked throughout the web.

Recommendation:
Ensure each interface is not bypassable using common knowledge of the application or leaked credentials using occasional password audits.

References:
https://pentest-tools.com/network-vulnerability-scanning/password-auditor
http://capec.mitre.org/data/definitions/16.html

Classification:
CWE : CWE-287
OWASP Top 10 - 2025 : A06 - Insecure Design
SOC 2 : CC6.1 - Logical access and session security
ISO 27001 : A.5.15 - Access control

File Upload

port 443/tcp

CONFIRMED

URL	Method	Parameters	Evidence

https://google-gruyere.appspot.com/6089779068945906258916178499883858380 39/upload.gtl	GET	**Headers:** User-Agent=Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/153.0.0.0 Safari/537.36	The following form allows file upload: `<form method="post" enctype="multipart/form-data" action="/6089779068945906258916178499883858380 39/upload2"> <table> <tbody><tr><td> <input type="file" name="upload_file" size="50"> </td></tr> <tr><td align="center"> <input type="submit" value="Upload"> </td></tr> </tbody></table> </form>` Request / Response

Details

Risk description:
The risk is that an attacker might use the file upload functionality for path traversal, persistent XSS, transmission of malware or denial of service, if such vulnerabilities are present.

Recommendation:
Use a server-generated filename, inspect the content of uploaded files, enforce a whitelist of non-executable file types and a size limit, and reject attempts to upload archive formats such as ZIP.

References:
https://cwe.mitre.org/data/definitions/434.html

Classification:
CWE : CWE-434
OWASP Top 10 - 2025 : A06 - Insecure Design
SOC 2 : CC6.6 - Security configuration, boundary protection, and exposure hardening
ISO 27001 : A.8.21 - Security of network services

Security.txt file is missing

CONFIRMED

port 443/tcp

URL
Missing: https://google-gruyere.appspot.com/.well-known/security.txt

Details

Risk description:
There is no particular risk in not having a security.txt file for your server. However, this file is important because it offers a designated channel for reporting vulnerabilities and security issues.

Recommendation:
We recommend you to implement the security.txt file according to the standard, in order to allow researchers or users report any security issues they find, improving the defensive mechanisms of your server.

References:
https://securitytxt.org/

Classification:
CWE : CWE-1188
OWASP Top 10 - 2017 : A6 - Security Misconfiguration
OWASP Top 10 - 2021 : A5 - Security Misconfiguration
OWASP Top 10 - 2025 : A02 - Security Misconfiguration
SOC 2 : CC7.4 - Security issue intake / reporting channel readiness
ISO 27001 : A.5.24 - Information security incident management planning and preparation

HTTP OPTIONS enabled

CONFIRMED

port 443/tcp

URL	Method	Summary
https://google-gruyere.appspot.com/6089779068945906258916178499883858380 39/	OPTIONS	We did a HTTP OPTIONS request. The server responded with a 405 status code and the header: `Allow: GET, POST` Request / Response

Details

Risk description:
The only risk this might present nowadays is revealing debug HTTP methods that can be used on the server. This can present a danger if any of those methods can lead to sensitive information, like authentication information, secret keys.

Recommendation:
We recommend that you check for unused HTTP methods or even better, disable the OPTIONS method. This can be done using your webserver configuration.

References:
https://techcommunity.microsoft.com/t5/iis-support-blog/http-options-and-default-page-vulnerabilities/ba-p/1504845
https://docs.nginx.com/nginx-management-suite/acm/how-to/policies/allowed-http-methods/

Classification:
CWE : CWE-16
OWASP Top 10 - 2017 : A6 - Security Misconfiguration
OWASP Top 10 - 2021 : A5 - Security Misconfiguration
OWASP Top 10 - 2025 : A02 - Security Misconfiguration
SOC 2 : CC6.6 - Security configuration, boundary protection, and exposure hardening
ISO 27001 : A.8.9 - Configuration management

Scan coverage information

List of tests performed (40)

Port 443

- ✔ Scanned for HttpOnly flag of cookie
- ✔ Scanned for Secure flag of cookie
- ✔ Scanned for missing HTTP header - Content Security Policy
- ✔ Scanned for missing HTTP header - Referrer
- ✔ Scanned for missing HTTP header - Strict-Transport-Security
- ✔ Scanned for missing HTTP header - X-Content-Type-Options
- ✔ Scanned for passwords submitted in URLs
- ✔ Scanned for robots.txt file
- ✔ Scanned for website technologies
- ✔ Scanned for file upload
- ✔ Scanned for enabled HTTP OPTIONS method
- ✔ Scanned for login interfaces
- ✔ Scanned for absence of the security.txt file
- ✔ Scanned for version-based vulnerabilities of server-side software
- ✔ Scanned for client access policies
- ✔ Scanned for use of untrusted certificates
- ✔ Scanned for enabled HTTP debug methods
- ✔ Scanned for secure communication
- ✔ Scanned for directory listing
- ✔ Scanned for passwords submitted unencrypted
- ✔ Scanned for error messages
- ✔ Scanned for debug messages
- ✔ Scanned for code comments
- ✔ Scanned for domain too loose set for cookies
- ✔ Scanned for mixed content between HTTP and HTTPS
- ✔ Scanned for cross domain file inclusion
- ✔ Scanned for internal error code
- ✔ Scanned for secure password submission

- ✔ Scanned for sensitive data
- ✔ Scanned for unsafe HTTP header Content Security Policy
- ✔ Scanned for OpenAPI files
- ✔ Scanned for SQL statement in request parameter
- ✔ Scanned for password returned in later response
- ✔ Scanned for Path Disclosure
- ✔ Scanned for Session Token in URL
- ✔ Scanned for API endpoints
- ✔ Scanned for emails
- ✔ Scanned for missing HTTP header - Rate Limit
- ✔ Scanned for PEM-encoded private key material
- ✔ Scanned for partial PEM-encoded private key material

Scan parameters

target:	https://google-gruyere.appspot.com/6089779068945906258916178499883858380 39/
scan_type:	Light
authentication:	False

Scan stats

Unique Injection Points Detected:	11
URLs spidered:	11
Total number of HTTP requests:	22
Average time until a response was received:	194ms